

Eng 3.4. Active Directory Hardening

Task 1 - Introduction

Active Directory (AD) is widely used by almost every big organisation to manage, control and govern a network of computers, servers and other devices.

Task 2 - Understanding General Active Directory Concepts

Domain: The domain acts as a core unit regarding the logical structure of the Active Directory. It initially stores all the critical information about the objects that belong to the domain only.

Domain Controller: A Domain Controller is an Active Directory server that acts as the brain for a Windows server domain; it supervises the entire network. Within the domain, it acts as a gatekeeper for users' authentication and IT resources authorisation.

Trees and Forests: Trees and Forests are the two most critical concepts of the Active Directory.

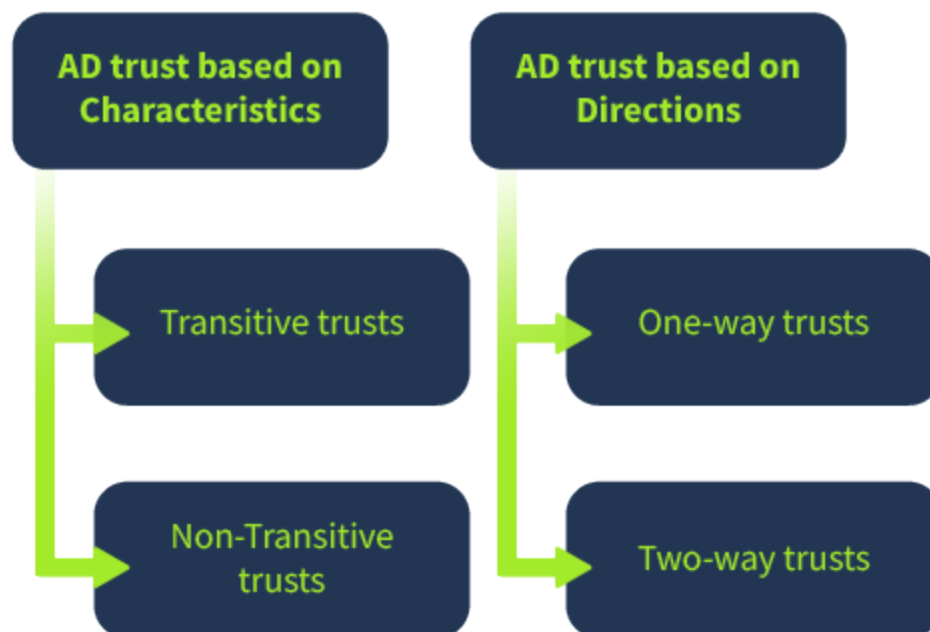


Trees: Trees are responsible for sharing resources between the domains. The communication between the domains inside a tree is possible by either one-way

or two-way trust. When a domain is added to the Tree, it becomes the Offspring domain of that particular domain to which it is added – now a Parent domain.

Forests: When the sharing of the standard global catalogue, directory schema, logical structure, and directory configuration between the collections of trees is made successfully, it is called a Forest. Communication between two forests becomes possible once a forest-level trust is created.

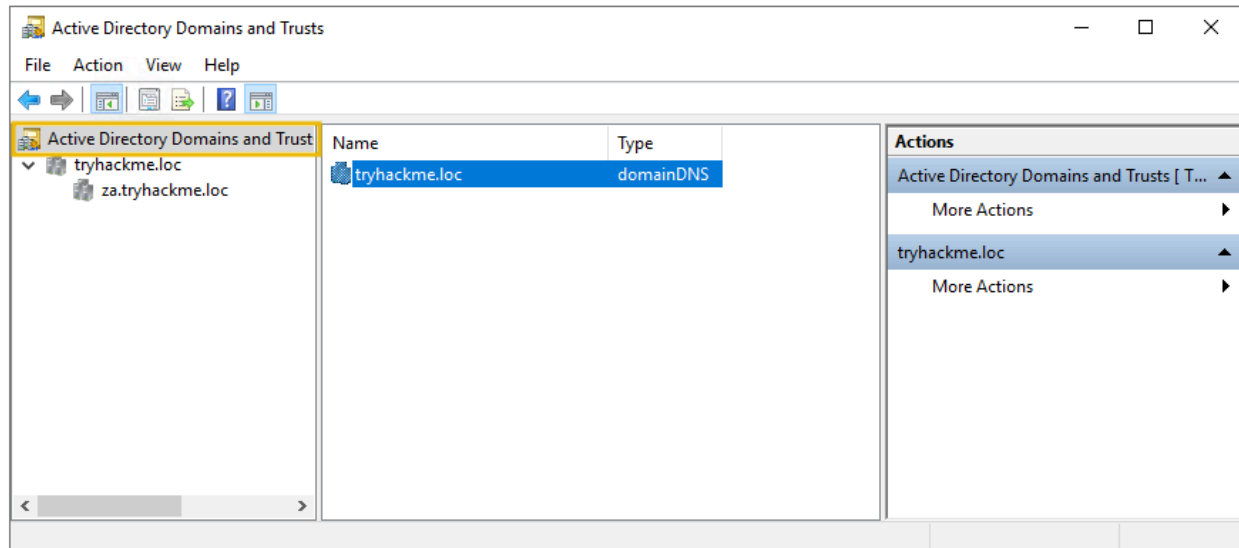
Trust in Active Directory: AD trust is the established communication bridge between the domains in Active Directory. When we say one domain trusts another in the AD network, it means its resources can be shared with another domain. However, one domain's resources are not directly available to every other domain, as it is not safe. Thus, the resource sharing availability is governed by Trusts in AD. The AD trusts are of two categories, which are classified based on their characteristics or the current direction.



AD trusts categorised based on characteristics are known as Transitive and non-Transitive trusts. Transitive trust reflects a two-way relationship between domains. If there are three domains, domain A trusts domain B and domain B has a transitive trust with domain C. Consequently, domain A will automatically trust domain C for sharing resources. Again, AD trusts are of two types when classified based on

their direction: One-way and Two-way trusts. You can access the AD trust through the following:

Server Manager > Tools > Active Directory Domains and Trust

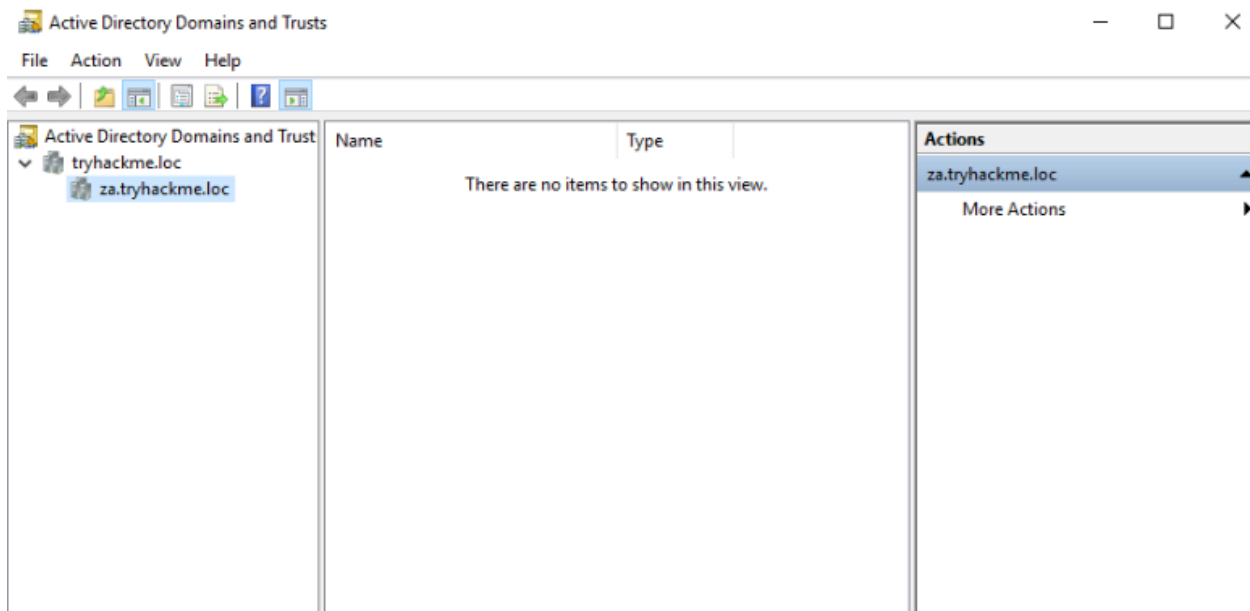


Container and Leaves: For those familiar, each network part is treated as an object in AD. Anything from resources, users, services, or part of the network can be an object. The hierarchical structure of AD defines that an object may or may not contain other objects based on the scenario. When an object holds another object, it is termed a container; otherwise, it is called the leaf object.

Answer the questions below

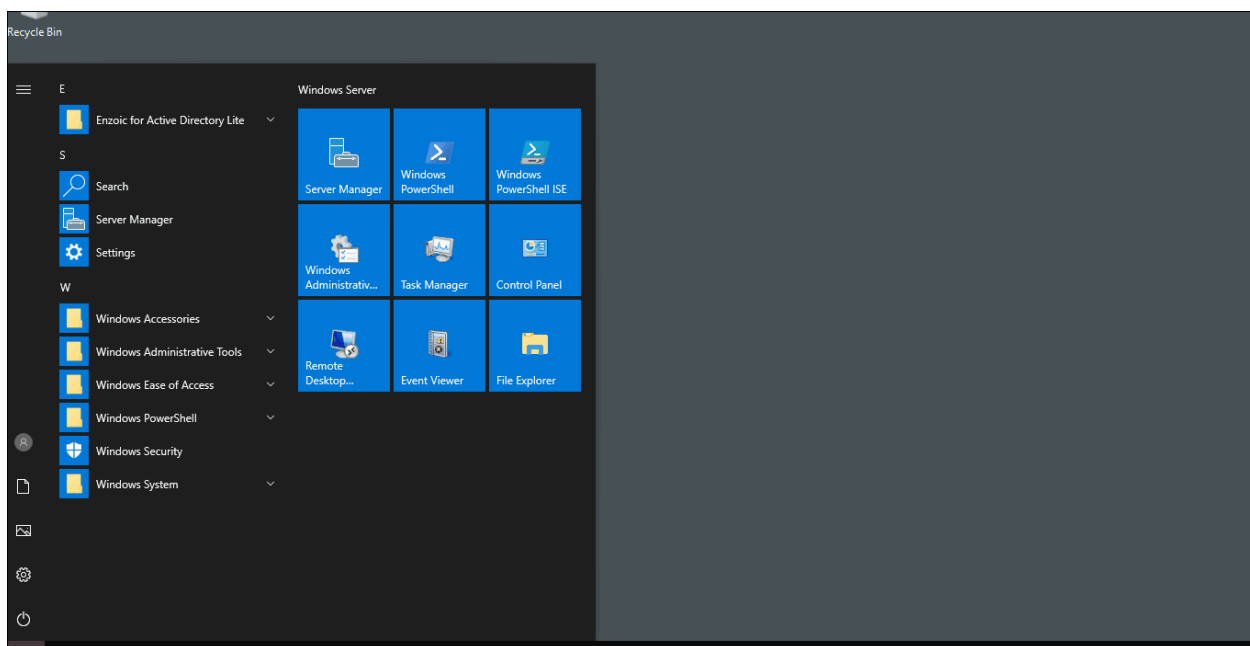
| What is the root domain in the attached AD machine?

tryhackme.loc



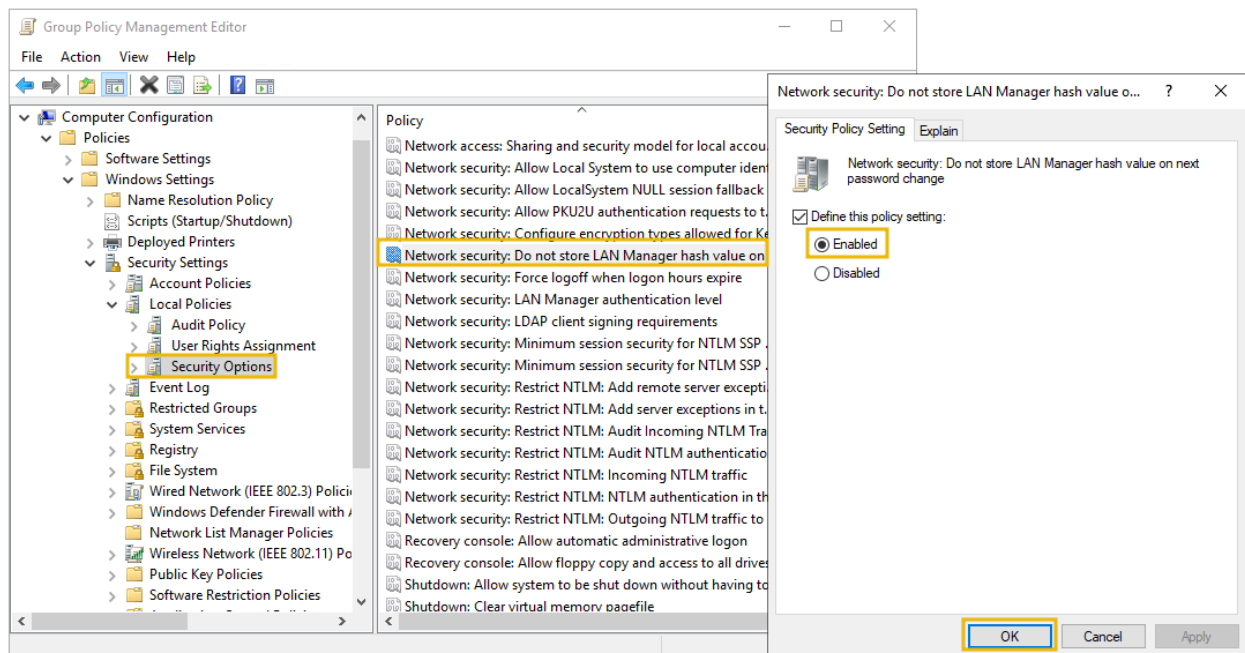
Task 3 - Securing Authentication Methods

In this task, we will briefly learn various security authentication methods that can be used for secure communication and ensuring data integrity from one machine to another in an AD environment. We will use the built-in Microsoft tool **Group Policy Management Editor** available in the attached AD machine for configuring various security policies. The instructions to access the tool are as below:



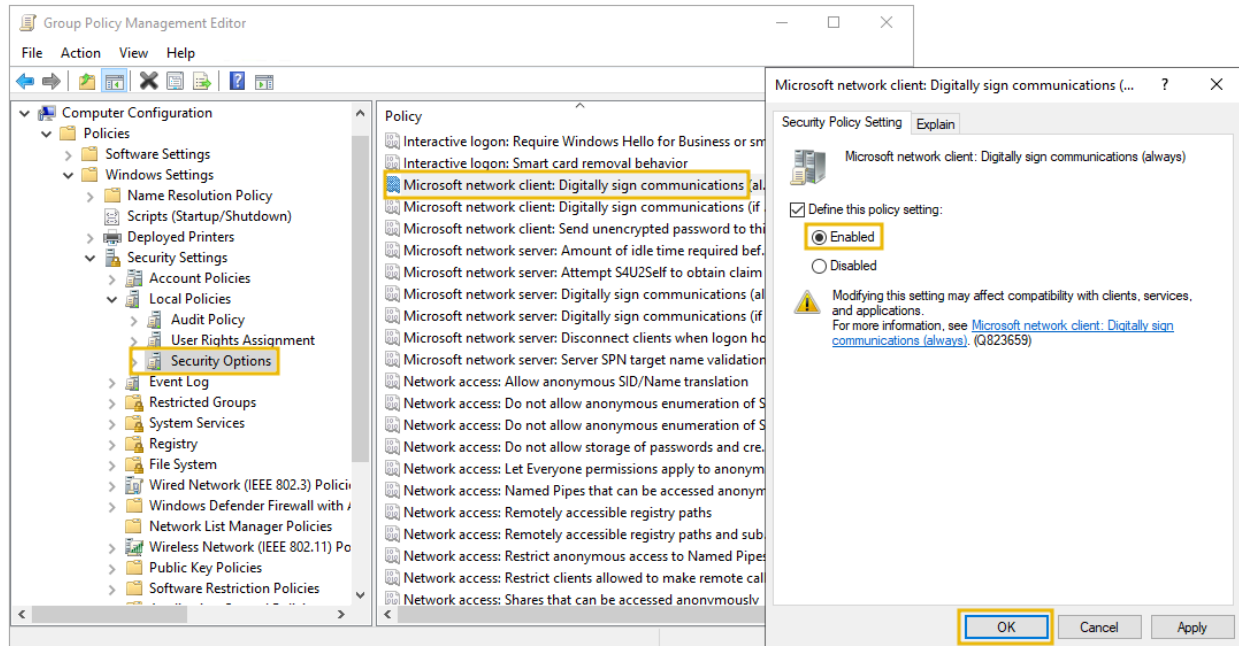
LAN Manager Hash: The user account password for Windows isn't stored in clear text; instead, it stores passwords with two types of hash representation. When the password for any user account is changed or set with fewer than 15 characters, both LM hash (LAN Manager hash) and NT hash (Windows NT hash) are generated by Windows and can be stored in AD. The LM hash is relatively weaker than the NT and is prone to a fast brute-force attack. The best recommendation is to prevent Windows from storing the password's LM hash. You can access it through the following:

Group Policy Management Editor > Computer Configuration > Policies > Windows Settings > Security Settings > Local Policies > Security Options > double click Network security - Do not store LM hash value on next password change policy > select "Define policy setting"



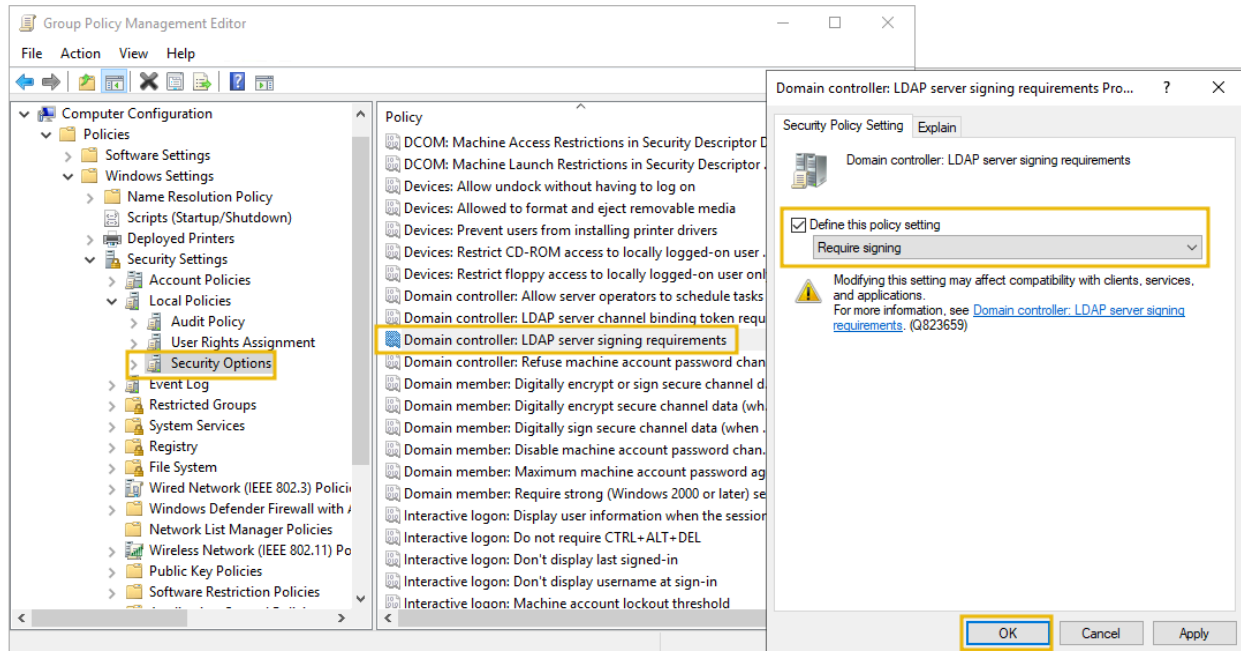
SMB Signing: SMB stands for Server Message Block. Generally, Microsoft-based networks utilise this protocol for file and print communication. Moreover, it allows secure transmission over the network. Configuring SMB signing through group policy is crucial to detect Man in the Middle (MiTM) attacks that may result in modification of SMB traffic in transit. SMB signing ensures the integrity of data for both client and server. All supported Windows versions have an SMB packet signing option.

Group Policy Management Editor > Computer Configuration > Policies > Windows Settings > Security Settings > Local Policies > Security Options > double click Microsoft network server: Digitally sign communication (always) > select Enable Digitally Sign Communications



LDAP Signing: Light Weight Directory Access Protocol (LDAP) enables locating and authenticating resources on the network. Hackers may introduce replay or MiTM attacks to launch custom LDAP requests. Therefore, LDAP signing is a Simple Authentication and Security Layer (SASL) property that only accepts signed LDAP requests and ignores other requests (plain-text or non-SSL). We can enable LDAP signing through the following:

Group Policy Management Editor > Computer Configuration > Policies > Windows Settings > Security Settings > Local Policies > Security Options > Domain controller: LDAP server signing requirements > select Require signing from the dropdown



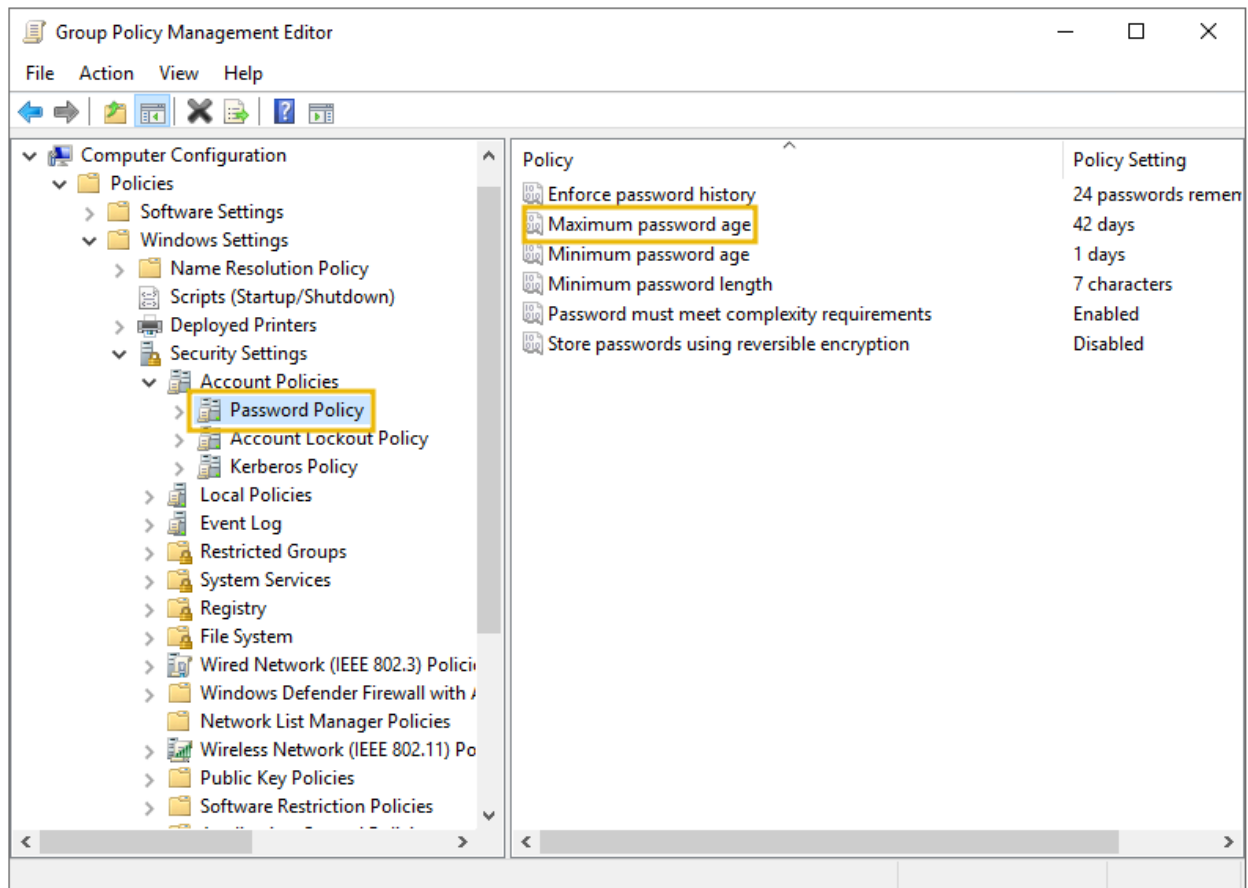
Password Rotation: Active Directory password security is critical to address because of security breaches and password reuse. It becomes challenging for any organisation to reset account passwords or update them everywhere, so they prefer not to do it. This scenario could have a few alternate approaches, and each method has pros and cons.

- **First Technique:** Creating a script to update passwords automatically in the Scheduled Task with the help of PowerShell. This method does not require any additional overhead and removes all the manual efforts for password rotation, but it requires you to write and maintain your script – which could be challenging.
- **Second Technique:** Add a Multi-Factor Authentication (MFA) solution to AD and choose not to change the password often. It adds a security layer, and you will not need to change your password often.
- **Third Technique:** Microsoft provides a solution for services account password rotation through Group Managed Services Accounts (gMSAs), which changes passwords after every 30 days.

Password Policies: Attackers use various corporate password-compromise techniques, including brute force, dictionary, password spraying, credential attacks etc. All organisations must have a strict password policy to defend against

all such attacks. Password policies mean different rules for creating passwords, including length, complexity, and changing frequency. For viewing and configuring the password policy, you can use the following:

Group Policy Management Editor > Computer Configuration > Policies > Windows Settings > Security Settings > Account Policies > Password Policy

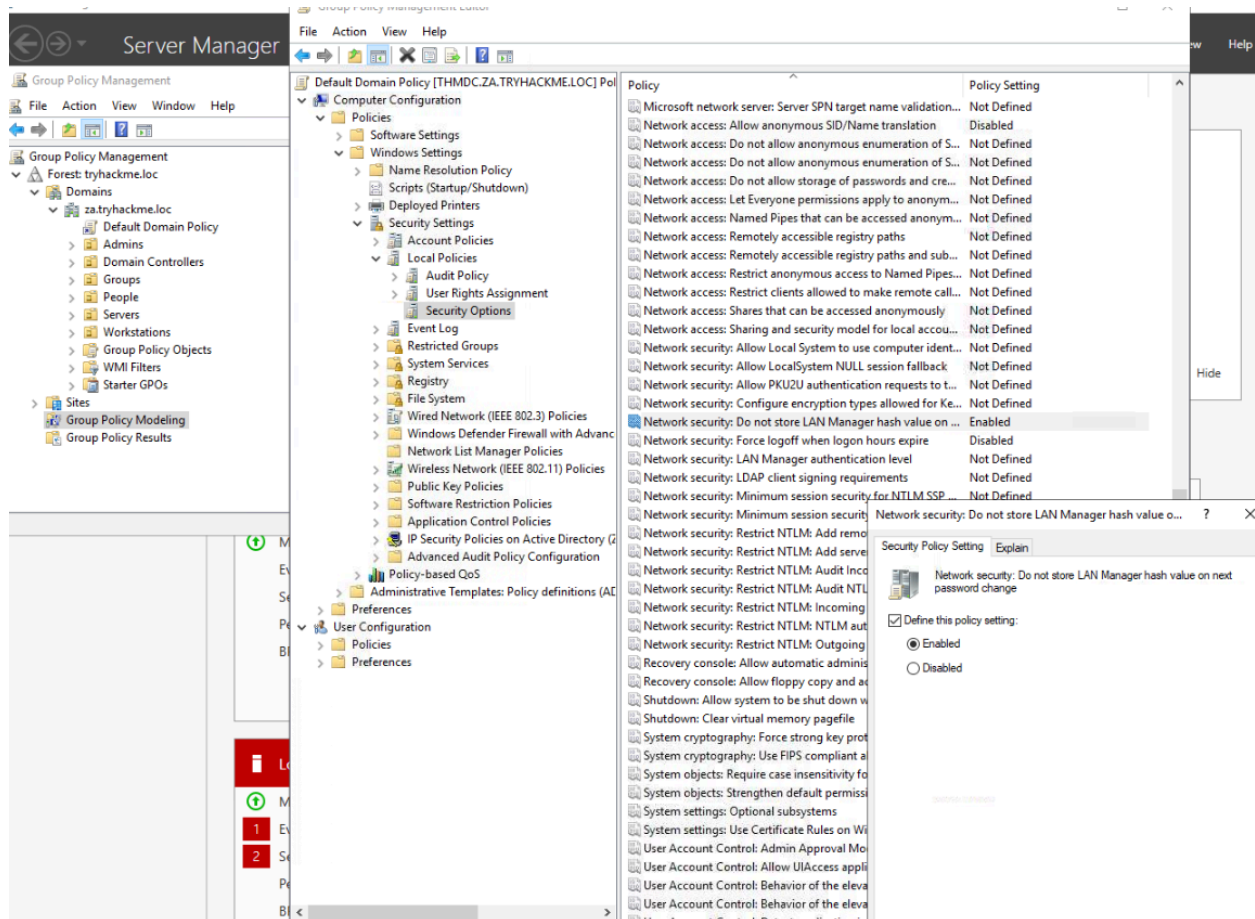


Understanding Password Policy Settings

- **Enforce password history:** Prevent at least 10 to 15 old passwords from being set as new ones.
- **Minimum password length:** The minimum password length should be set between 10 to 14.
- **Complexity requirements:** Must not contain the name of the user account and ensure the password has uppercase letters, lowercase letters, digits, or special characters.

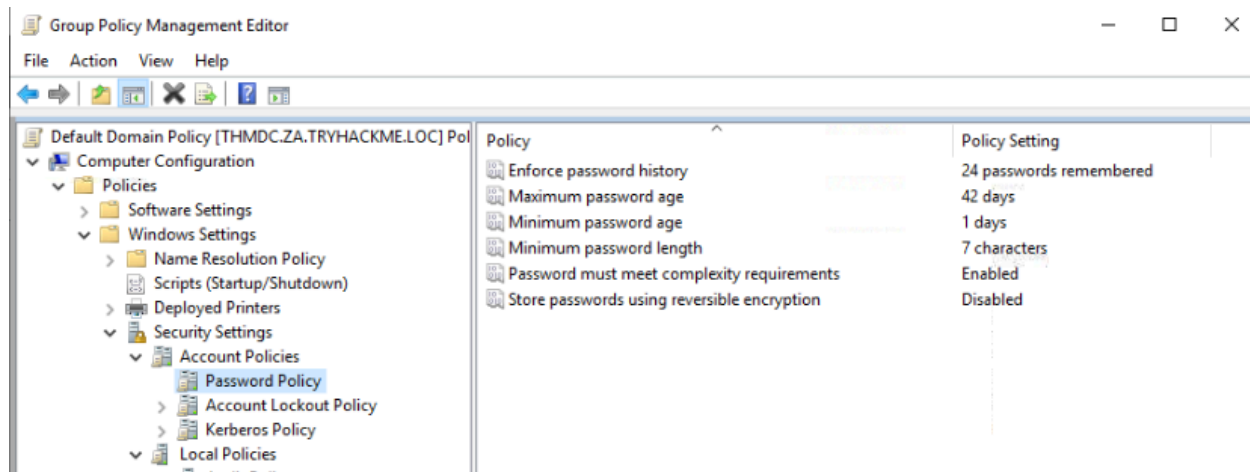
Answer the questions below

Change the Group Policy Setting in the VM, so it does not store the LAN Manager hash on the next password change.



What is the default minimum password length (number of characters) in the attached VM?

7



Task 4 - Implementing Least Privilege Model

Implementing the least privilege model requires limiting the user or application access to minimise security risks and attack surfaces. When the application or the users are allowed to operate with administrative privileges, they are granted complete access to modify, alter, create other resources on the system and perform any action with administrative rights. Contrary to this, the least privilege model grants limited and authorised access per current conditions.

Creating the Right Type of Accounts

Implementing the least privilege model requires setting up the different account types for diverse purposes. It includes the following account types:

- **User accounts:** You must promote using regular user accounts for most people in the network, who are necessary to perform their regular duties.
- **Privilege accounts:** These are the accounts with elevated privileges and are further classified as first and second privilege accounts.
- **Shared accounts:** These accounts are shared amongst a group of people, as the visitors with bare minimum privileges, to give limited access for a specific time. These accounts are not recommended and must be utilised in limited scenarios.

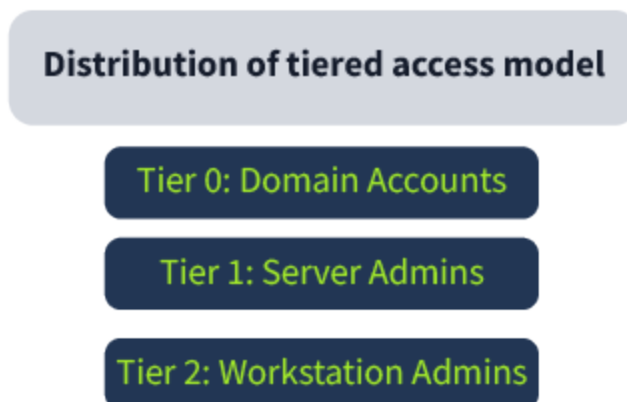
Role-Based Access Control on Hosts:

Role-based access control allows you to indicate access privileges at different levels. It includes DNS zone, server, or resource record levels and specifies who

has access control over creating, editing, and deleting operations of various resources of Active Directory.

Tiered Access Model: The Active Directory Tiered Access Model (TAM) comprises plenty of technical controls that reduce the privilege escalation risks. It consists of a logical structure that separates Active Directory's assets by creating boundaries for security purposes. The primary goal is the protection of Active Directory's top-valued identities (Tier 0). At the same time, domain members and other users can perform routine tasks, such as email checking, surfing the internet, and using apps and other services (Tier 1, 2). It comprises three tiers, Tier 0, 1, and 2, which are as follows:

- **Tier 0:** Top level and includes all the admin accounts, Domain Controller, and groups.
- **Tier 1:** Domain member applications and servers.
- **Tier 2:** End-user devices like HR and sales staff (non-IT personnel).



Implementation of Tiered Access Model: The critical implementation of this model is based on the principle of *"Prevention of privileged credentials from crossing boundaries, either accidentally or intentionally"*. Implementing technical controls via Group Policy Objects is crucial to avoid such scenarios. These Group Policy Objects put together the security rights that can deny access or grant permission.

Auditing Accounts: Accounts audit is a crucial task mainly carried out by setting up the correct account, assigning privileges, and applying restrictions. Three audit

types related to accounts must be done periodically: usage, privilege, and change audits.

- Usage audits allow monitoring each account's specific tasks and validating their access rights.
- A privilege audit allows you to check if every account in the system has the least privilege.
- Change audits allow you to look for any improper changes to account permissions, passwords, or settings. Any unacceptable change to these may lead to a data breach.

Answer the questions below

Computers and Printers must be added to Tier 0 - yea/nay?

nay

Suppose a vendor arrives at your facility for a 2-week duration task. Being a System Administrator, you should create a high privilege account for him - yea/nay?

nay

Task 5 - Microsoft Security Compliance Toolkit

Microsoft Security Compliance Toolkit (MSCT) is an official toolkit provided by Microsoft to implement and manage local and domain-level policies. You don't have to worry about complex policy syntaxes and scripts, as Microsoft will provide pre-developed security baselines per the end user environment.

Installing Security Baselines: Microsoft offers its customers security baselines readily available in consumable formats, like, Group Policy Objects Backups. You can easily download it as zip files and extract the content. Here is how you can download and install the security baselines for Windows Server in a simple way:

Open Microsoft Security Compliance Website > click Download > click Windows Servers Security Baseline.zip > Download

Choose the download you want

☐ File NameSize

☐ Windows 10 Version 20H2 and Windows Server Version 20H2 Security Baseline.zip	1.5 MB
☐ Windows 10 version 21H2 Security Baseline.zip	1.2 MB
☐ Windows 10 version 22H2 Security Baseline.zip	1.2 MB
☐ Windows 11 Security Baseline.zip	1.2 MB
☐ Windows Server 2012 R2 Security Baseline.zip	699 KB
☐ Windows Server 2022 Security Baseline.zip	1.3 MB

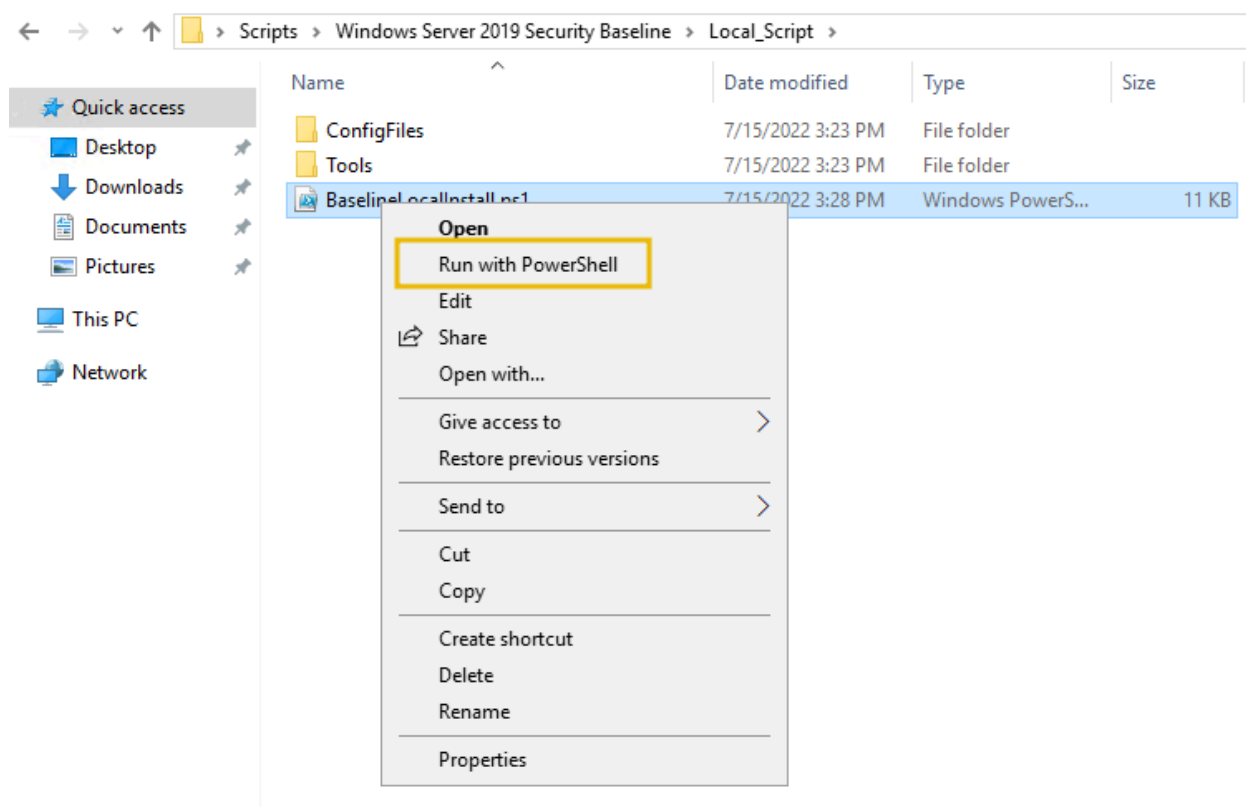
Download Summary:
KBMBGB

You have not selected any file(s) to download.

Total Size: 0

Next

Open extracted folder > Scripts > & select desired baseline & execute with PowerShell



Policy Analyser: One of the Security Compliance Toolkit's features is a policy analyser which allows comparison of group policies to quickly check inconsistencies, redundant settings, and the alterations that need to be made between them. Consider a scenario where plenty of GPOs are applied at diverse

levels. There will be conflicting, redundant settings and many more avenues that can be quickly resolved with a policy analyser.

Choose the download you want

☐ File Name

Size

☐ Microsoft 365 Apps for Enterprise-2206-FINAL.zip722 KB

☐ Microsoft Edge v112 Security Baseline.zip352 KB

☐ PolicyAnalyzer.zip1.5 MB

☐ SetObjectSecurity.zip314 KB

☐ Windows 10 Update Baseline.zip453 KB

☐ Windows 10 Version 1507 Security Baseline.zip904 KB

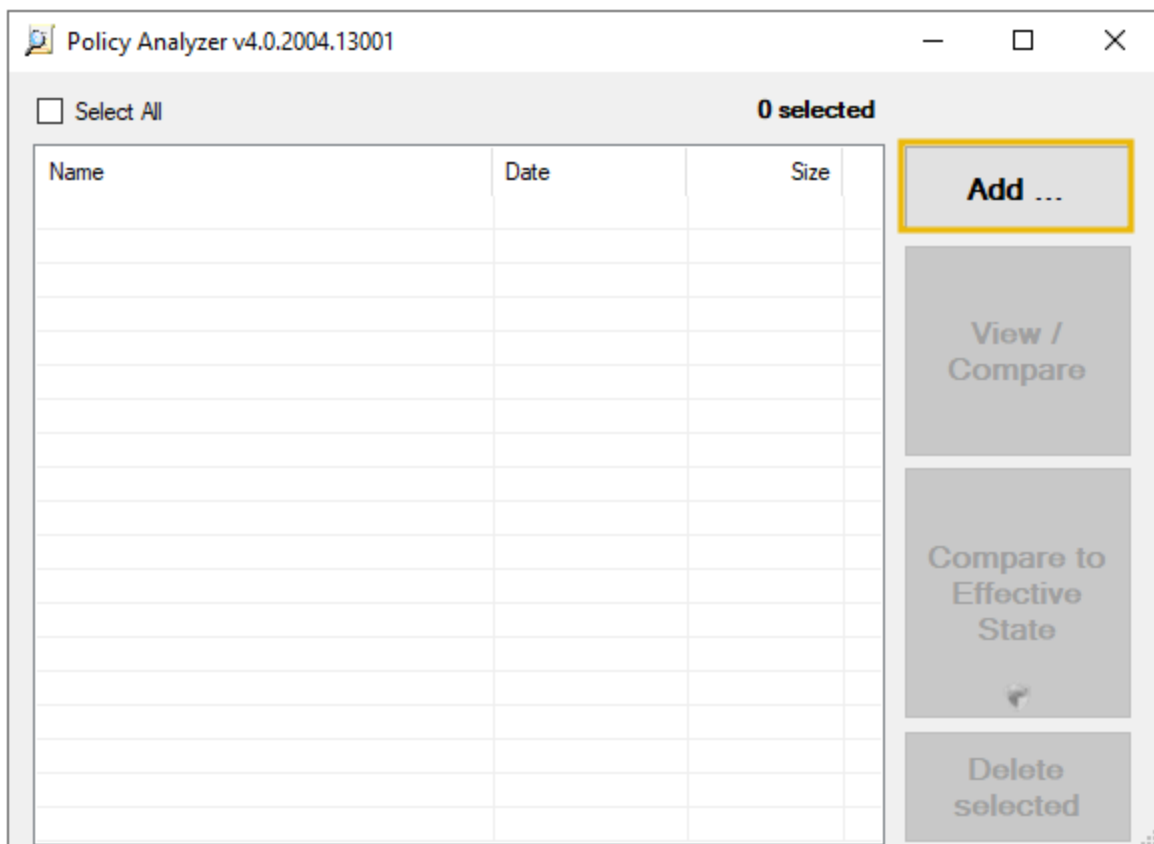
Download Summary:
KBMBGB

You have not selected any file(s) to download.

Total Size: 0

Next

Once downloaded, you can run the `PolicyAnalyzer.exe` to add and manage local or domain-level policies.

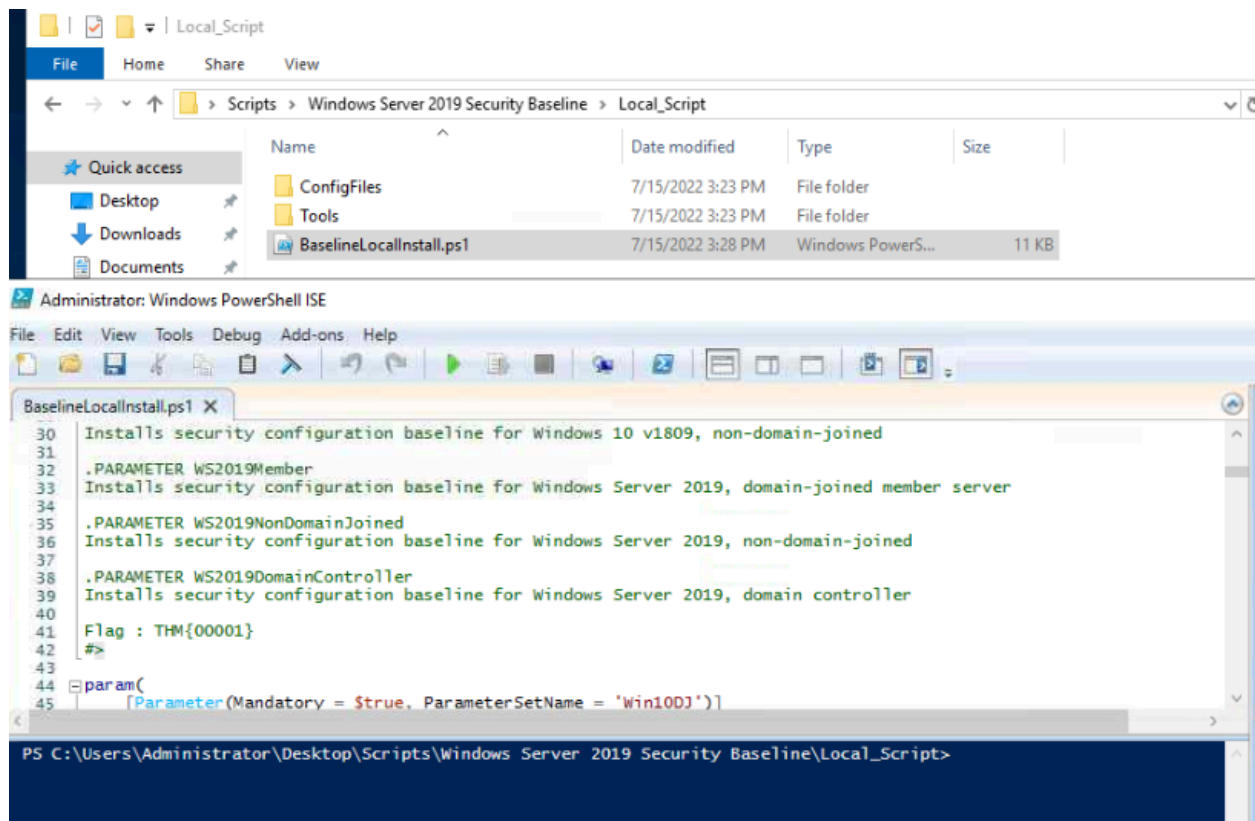


Be careful while downloading security baselines, as they should only be downloaded from the official Microsoft website.

Answer the questions below

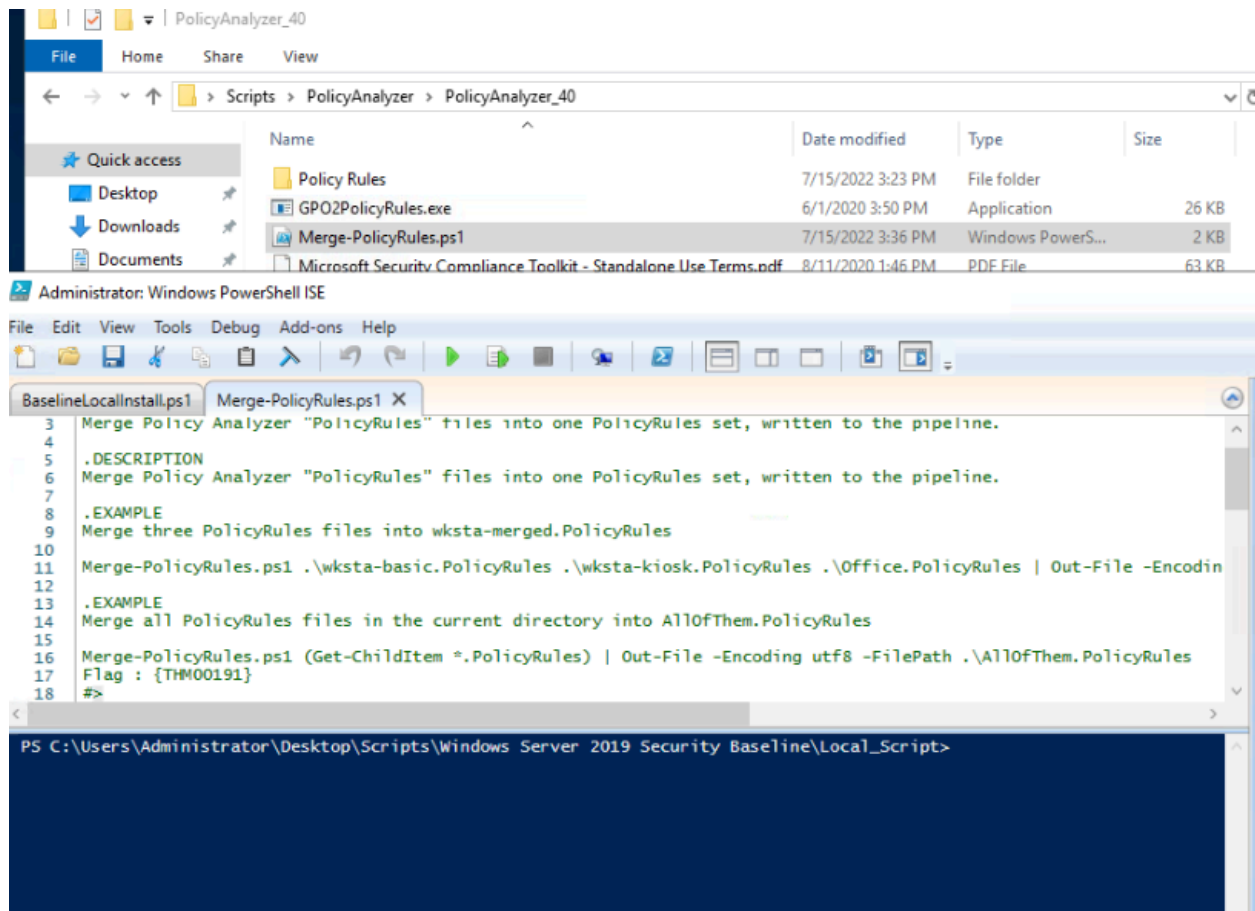
Find and open BaselineLocalInstall script in PowerShell editor - Can you find the flag?

THM{00001}



Find and open MergePolicyRule script (Policy Analyser) in PowerShell editor - Can you find the flag?

{THM00191}



Task 6 - Protecting Against Known Attacks

If an intruder successfully gains domain admin account access, you may consider that the game is over. No one is ever ready to disclose the company's confidential data or for financial loss. Before we discuss some known attacks, it is crucial to think like an attacker and develop a mindset wearing their shoes.

- Zero Logon (Get admin access to an AD without credentials).
- Breaching AD (Getting the first set of credentials in an AD environment).
- Exploiting AD (Learn common AD exploitation techniques).
- Post-Exploitation basics (What an attacker does after gaining an initial foothold of AD).

Kerberoasting: Kerberoasting is a common and successful post-exploitation technique for attackers to get privileged access to AD. The attacker exploits Kerberos Ticket Granting Service (TGS) to request an encrypted

password, and then the attacker cracks it offline through various brute force techniques. These attacks are difficult to detect as the request is made through an approved user, and no unusual traffic pattern is generated during this process. You can prevent the attack by ensuring an additional layer of authentication through MFA or by frequent and periodic Kerberos Key Distribution Centre (KDC) service account password reset.

Weak and Easy-to-Guess Passwords: The easiest target for intruders to breach security is the weak and easy-to-guess old passwords. The best recommendation is to use strong passwords and avoid already known ones. A strong password consists of a combination of uppercase and lowercase letters, numbers, and special characters. You can see a report generated through a free tool on [Desktop > Password-Report.png](#).

Brute Forcing Remote Desktop Protocol: The intruders or attackers use scanning tools to brute force the weak credentials. Once the brute force is successful, they quickly access the compromised systems and try to do privilege escalation along with a persistent foothold in the target's computer. The best recommendation is to never expose RDP without additional security controls to the public internet. Continuous audits for scanning attacks or brute-force attempts are also an important step.

Publicly Accessible Share: During AD configuration, some share folders are publicly accessible or left unauthenticated, providing an initial foothold for attackers for lateral movement. You can use the `Get-SmbOpenFile` cmdlet in PowerShell to look for any undesired share on the network and configure access accordingly.

Answer the questions below

Does Kerberoasting utilise an offline-attack scheme for cracking encrypted passwords?

yea

As per the generated report, how many users have the same password as aaron.booth?

186

Paint application window titled "Password-Reports.PNG - Paint". The interface shows the standard Windows Paint ribbon with tabs for File, Home, and View. The Home tab is active, displaying various drawing tools like Paste, Cut, Copy, Select, Crop, Resize, Rotate, and a range of drawing tools including pens, brushes, eraser, and selection tools. The Shapes section is also visible.

The main content area displays a screenshot of a "Domain Check Results" report. At the top of the report is a button labeled "Export to CSV". Below this is a table with the following data:

Username	Password Weak/Compromised	Exposure	Number of Accounts With Same Password
aaron.adams	No	N/A	0
aaron.booth	No	N/A	186
aaron.dickinson	No	N/A	0
aaron.duffy	No	N/A	0
aaron.fisher	No	N/A	0
aaron.giles	No	N/A	0
aaron.harvey	No	N/A	0
aaron.jones	No	N/A	181
aaron.lee	No	N/A	0
aaron.thomas	No	N/A	0
abbie.daniels	No	N/A	0
abbie.gilbert	No	N/A	0
abbie.green	No	N/A	9
abbie.hill	No	N/A	156
abbie.jackson	No	N/A	0
abbie.jones	No	N/A	156
abbie.lee	No	N/A	186
abbie.morgan	No	N/A	0

The bottom status bar of the Paint application shows the image dimensions as 1366 x 728px and the file size as 85.9KB.

Task 7 - Windows Active Directory Hardening Cheat Sheet



Level - 1: Implementing Least Privilege Model

Actions: Restrict Privileged Domain Accounts > Auditing Accounts (Misconfigurations, security loop holes) > Privilege Management (Administrating Tier 0,1 & 2 Users) > Role-based Access Control

Level - 2: Securing Authentication Methods

Actions: Password Rotation > Protecting Credential Theft > Multi Factor Authentication > SMB Signing

Level - 3: Protecting Against Known Attacks

Actions: Kerberoasting > Weak & Easy to Guess Passwords > Brute Forcing Remote Desktop Protocol > Publicly Accessible Share

Level - 4: Microsoft Security Compliance Toolkit

Actions: Installing Security Baselines > Analyzing Group Policies Analyzer > Local Group Policy Object